SEMANTIC GRAVITY

Unified Risk Intelligence Platform

Solution Blueprint v2.0

Prepared for: Royal Enfield
Prepared by: Semantic Gravity
May 2026 | Classification: Confidential

1. Executive Summary

Royal Enfield currently manages cybersecurity risk across 9 disparate sources — all manually consolidated into an Excel risk register. This blueprint proposes a Unified Risk Intelligence Platform (URIP) that aggregates all risk feeds, applies exploitability-first prioritization, automates assignment and SLA tracking, and delivers a single dashboard for CISO, IT, and executive stakeholders.

URIP does not replace existing security tools. It acts as an orchestration and intelligence layer on top of the existing stack.

KEY ENVIRONMENT — ROYAL ENFIELD

Security Tool Stack	CrowdStrike, Forescout NAC, Cisco ISE, CyberArk PAM, Zscaler ZTA/ZIA/CASB, Fortiguard, Google Workspace, Armis (OT)
Risk Sources	14 — 9 core risk inputs + 5 security tool connectors
Risk Scoring	CVSS v4.0 (client current). URIP adds EPSS + KEV + Asset Criticality composite layer on top
Current Tracking	Manual Excel risk register — no SLA, no auto-assignment, no remediation tracking

2. Problem Statement

Problem 1	Multiple risk sources in separate consoles — no unified view. Teams spend hours consolidating manually.
Problem 2	All risks entered into Excel — no SLA, no auto-assignment. SPOCs take their own time. No accountability.
Problem 3	Risk accepted by HoD — no recommendation given, still counts in board reports. Reports inflated.
Problem 4	Low-impact vulnerabilities fixed first. Zero-Days and Critical exploits wait. Resources wasted on noise.

3. Intelligence & Enrichment Engine

This section defines the complete intelligence pipeline — from raw input to prioritized, enriched output. This logic is defined once here and referenced throughout the document.

3.1 Core Workflow

DETECT → NORMALIZE → DEDUPLICATE → ENRICH → SCORE → ASSIGN → REPORT

DETECT	Pull live feeds from all 14 sources via API connectors and file uploads
NORMALIZE	Convert all severity formats to unified CVSS-equivalent 0-10 scale (see Section 3.3)
DEDUPLICATE	Asset fingerprinting merges duplicate findings across sources (see Section 3.4)
ENRICH	Apply EPSS + KEV + Asset Criticality + APT tags + IOC matching (see Section 3.5)
SCORE	Compute composite score: max(0, min(10, 0.55×CVSS + 2.5×EPSS + KEV_bonus + asset_bonus))
ASSIGN	Auto-assign to product owner / SPOC per domain — trigger SLA countdown
REPORT	CISO dashboard + board report + CERT-In compliance — accepted risks excluded

3.2 14 Data Source Connectors

#	Source	Tool (RE Stack)	Data Type	Integration
CORE 9 — Primary Risk Sources (Client Requested)				
1	Spotlight (VM)	CrowdStrike Falcon	CVEs, endpoints	REST API
2	EASM	CrowdStrike / External	External attack surface	REST API
3	CNAPP	CrowdStrike Cloud	Cloud misconfigs	REST API
4	OT Environment	Armis	OT asset vulns	Armis API
5	VAPT Reports	External Vendor	Pentest findings	Portal / File Upload
6	Threat Intelligence	External Feed	Active exploit intel	Feed / API
7	CERT-In Advisories	CERT-In Portal	Govt advisories	RSS / Manual
8	Bug Bounty	Internal/External	Researcher findings	Webhook / Upload
9	SoC Alerts	SIEM / SoC Team	Live incident alerts	SIEM API / Webhook
EXTENDED 5 — Security Tool Stack (Semantic Gravity Value-Add)				
10	Network Access Control	Forescout NAC / Cisco ISE	Rogue devices, NAC alerts	Syslog / API
11	Privileged Access Risk	CyberArk PAM	Shared credentials,	REST API

			privilege abuse	
12	Cloud Access / Shadow IT	Zscaler ZTA / CASB	Unauthorized apps, policy violations	Zscaler API
13	Firewall Threat Events	Fortiguard Firewall	Blocked threats, anomalies	Syslog
14	Email Security	Google Workspace	Phishing, BEC alerts	Google API

3.3 Normalization Engine — Unified Severity Scale

Not all 14 sources use CVSS. URIP normalizes every finding to a 0-10 CVSS-equivalent scale before scoring. This enables comparison across all sources in a single register.

Source	Native Format	Mapping Method	Example
CrowdStrike (Spotlight/EASM/CNAPP)	ExPRT score 0-100	Divide by 10	ExPRT 85 → 8.5
Armis (OT)	0-10 or 0-100	Normalize to 0-10	Armis 7.5 → 7.5
VAPT Reports	CVSS 0-10 (vendor)	Use directly	CVSS 8.5 → 8.5
CERT-In Advisories	Critical/High/ Medium/Low	Rule map → CVSS equiv	Critical → 9.0
Bug Bounty	P1/P2/P3/P4	Heuristic model (see below)	P1 → 9.0 base
SoC Alerts	Critical/High/ Medium/Low	Rule map → CVSS equiv	High → 7.5
Forescout / Cisco ISE	Event severity	Rule map → CVSS equiv	Critical event → 8.0

HEURISTIC SCORING MODEL — For Non-CVE Findings

For findings without a CVE ID (Bug Bounty, VAPT narrative findings), URIP applies a Heuristic Scoring Model that simulates EPSS/KEV logic based on Exploit Maturity reported by the researcher or vendor. This ensures a uniform 0-10 scale across all 14 sources without fabricating CVE data.

```
Step 1: CVE ID present? → Fetch actual CVSS + EPSS from NVD/FIRST.org (most accurate)
Step 2: No CVE, but description present? → NLP keyword match on vulnerability type
         "Remote Code Execution" → 9.5  |  "SQL Injection" → 8.5  |  "XSS" → 6.0
Step 3: No CVE, no description? → Rule-based severity map (P1=9.0, P2=7.5, P3=5.0, P4=2.5)
EPSS fallback (non-CVE): Critical=0.30  High=0.20  Medium=0.10  Low=0.05
```

3.4 Normalization & De-duplication Engine

When multiple sources report the same vulnerability on the same asset, URIP merges them into a single finding — preventing data bloat and double-counting in the risk register.

ASSET FINGERPRINTING — De-duplication Logic

```
Asset Identity = MAC Address + Hostname + IP Address (composite key)

EXAMPLE: CrowdStrike reports 'Log4j High' on 192.168.1.50 (SAP-PRD-01)
         VAPT report says 'CVE-2021-44228 Critical' on SAP-PRD-01
         → URIP matches: same CVE + same asset fingerprint → MERGED
         → Highest enriched composite score retained
         → Source attribution preserved: 'Reported by: CrowdStrike + VAPT'

OT NETWORK NOTE: Armis data in isolated segment → On-Premise Collector or
Secure API Gateway/Proxy pulls data without compromising network isolation.
```

3.5 Composite Scoring Formula — Final

COMPOSITE SCORE — Codex + Kimi Consensus (Additive)

```
composite = max(0.0, min(10.0,  0.55×CVSS  +  2.5×EPSS  +  KEV_bonus
+  asset_bonus))

KEV_bonus   = +2.0  (CVE confirmed in CISA KEV catalog)  |  0.0  (not in KEV)
asset_bonus = +1.0 Tier 1  |  +0.5 Tier 2  |  0.0 Tier 3  |  -0.5 Tier 4
EPSS        = Live from FIRST.org daily  |  Fallback: Crit=0.30 High=0.20
Med=0.10 Low=0.05
max(0.0,...)  floor prevents negative scores on Tier 4 low-CVSS findings
```

Component	Contribution	Industry Precedent	Rationale
CVSS (0.55×)	0.0 — 5.5	Everyone	Base severity — necessary but not dominant
EPSS (2.5×)	0.0 — 2.5	CISA, Tenable, CrowdStrike	Exploit probability — key differentiator
KEV (+2.0)	0 or 2.0	CISA federal mandate	Confirmed active exploitation = non-negotiable boost
Asset Bonus	-0.5 to +1.0	CrowdStrike, Qualys, Rapid7	Same CVE, different asset = different priority
APT Tag	Display only	Mandiant, MS Defender TI	WHO is exploiting — context on risk row, not in score
SSVC Label	Decision label	CISA, Tenable	ACT NOW / ACT / ATTEND / TRACK — shown alongside score

3.6 Asset Criticality Tiers

Asset criticality is pulled from CrowdStrike tags and ServiceNow CMDB Business Criticality fields. Keyword matching is used only as a failsafe for untagged assets — it is not the primary method.

Primary Source (Production)	CrowdStrike API → asset_criticality tag (Critical/High/Medium/Low) → maps to Tier 1-4. ServiceNow CMDB Business Criticality field → maps to Tier. Zero manual work.
Failsafe (Untagged Assets)	Keyword match on asset_name: SAP/ERP/HMI/SCADA/PLC/OT/Payment → Tier 1. Dealer/VPN/WAF → Tier 2. Wiki/Workstation → Tier 3. Test/Dev/Staging → Tier 4.
Manual Override	IT team overrides via portal UI — one click, no code deploy. Audit trail maintained. Takes precedence over auto-assignment.
Asset Registry	asset_name → auto_tier → manual_tier → final_tier. Rule: final_tier = manual_tier IF SET, else auto_tier.

3.7 Enrichment Layer — Live Status

#	Capability	Source	Status	On Risk Rows?	In Score?
1	EPSS	FIRST.org API	✅ **LIVE**	✅ Yes	✅ Yes (2.5×)
2	CISA KEV	CISA JSON	✅ **LIVE**	✅ Yes	✅ Yes (+2.0)
3	Asset Criticality	CrowdStrike + CMDB	✅ **LIVE**	✅ Yes	✅ Yes (+1.0 to -0.5)
4	APT Tags (MITRE)	MITRE ATT&CK JSON	✅ **LIVE / WIRED**	✅ Yes	❌ Context only
5	IOC Matching	OTX indicators	✅ **LIVE / WIRED**	✅ Auto-creates Critical	❌ Score 10.0 on match
6	Geo Threat Map	OTX + MaxMind	✅ **LIVE**	⚠️ Separate page	❌ Context
7	Dark Web Monitor	Simulated data	⚠️ **SIMULATED**	⚠️ Dashboard KPI	❌ Context
8	RE Network Logs	Client SIEM	❌ **POST GO-LIVE**	❌ Needs SIEM	❌ Future

KEY DEMO STATEMENT

"Consider two vulnerabilities: CVSS 9.8 with no active exploitation anywhere in the world — composite score 3.3, SSVC = TRACK. Versus CVSS 7.2, CISA-confirmed weaponized, running on SAP ERP, used by APT28 targeting Indian manufacturing — composite score 9.3, SSVC = ACT NOW. URIP automatically elevates the lower CVSS vulnerability because real-world exploit data shows it is the more dangerous one. This is the same framework CrowdStrike Spotlight already uses. An Excel register can never do this."

4. Operational Integration

This section covers how URIP connects to existing operational tools — ticketing, notifications, escalation, and OT network access — the practical plumbing that IT managers and security operations teams care about.

4.1 Jira / ServiceNow Integration

Trigger	Risk assigned to SPOC in URIP → Jira/ServiceNow ticket auto-created immediately
Ticket Contents	CVE ID, composite score, SSVC label, asset name, asset tier, APT context, SLA due date, remediation steps
Parent-Child	Complex findings broken into sub-tasks: patch deployment, WAF rule, re-test. Each sub-task = separate ticket with own SLA
Bi-directional	Ticket closed in Jira → URIP risk status auto-updated to Resolved. No manual sync needed
Closure Rule	Parent risk closes only when ALL child sub-task tickets are resolved + evidence uploaded

4.2 SLA Engine & Notifications

Severity	SLA	Alert Trigger	Escalation
Critical	72 hours	Immediate — SPOC + Manager notified	Auto-page CISO if unacknowledged in 4 hours
High	7 days	Alert at Day 5 (48hr warning)	Escalate to HoD at Day 6
Medium	30 days	Alert at Day 25	Escalate to manager at Day 28
Low	90 days	Alert at Day 80	No escalation — batch review

4.3 OT Network Access — Armis in Isolated Segment

Challenge	Armis OT data resides in a separate, air-gapped or VLAN-isolated network segment not reachable from corporate network
Solution A	On-Premise Collector: Lightweight agent deployed inside OT network segment. Pulls Armis API data locally, sends encrypted summary to URIP cloud/server
Solution B	Secure API Gateway / Proxy: Dedicated proxy server in DMZ between OT segment and URIP. Armis pushes to proxy, URIP pulls from proxy. No direct OT-to-internet path
Security Guarantee	Neither option exposes OT network to internet. All data transit encrypted (TLS 1.3). URIP never has direct access to OT assets — only to Armis API output

Decision	Architecture choice depends on Royal Enfield's network topology. Both options ready. Discussed during onboarding.

4.4 API Rate Limits — How URIP Handles Them

Zscaler CASB	Rate limit managed via batched polling (15-min intervals). Token refresh handled automatically.
CrowdStrike API	Falcon API uses OAuth 2.0. URIP respects rate headers and implements exponential backoff on 429 responses.
FIRST.org (EPSS)	Batch requests — 100 CVEs per call. 24-hour in-memory cache. Reduces API calls by ~95%.
CISA KEV	Full catalog downloaded once per 24 hours as JSON. Stored in-memory as hash set for instant lookups.
Armis API	Configured per Armis rate guidance. On-Premise Collector handles scheduling to stay within limits.

5. Portal Modules

5.1 Risk Dashboard

- Org-level composite risk score — aggregated across all 14 sources
- Breakdown by domain: Endpoint, Cloud, Network, Application, Identity, OT
- Risk trend chart (weekly/monthly) — posture improving or degrading
- Critical & High count with SLA breach alerts
- Dark Web KPI — credential exposure count (simulated for demo)
- Geo Threat Map link — India attack origin cluster
- Role-based views: CISO, IT Team, Executive/Board

5.2 Risk Register — Replaces Excel

- Auto-populated from all 14 source connectors
- Columns: ID | Title | Source | CVE | CVSS | Composite | Severity | SSVC | APT | Asset | Tier | Owner | Status | SLA Due
- Filter by severity, source, domain, SSVC label, owner, APT group, asset tier
- Bulk assign, bulk status update, bulk export
- Full audit trail per finding — every change logged

5.3 Risk Acceptance Workflow

- Owner flags risk for acceptance → system auto-generates Compensating Controls recommendation
- Recommendation includes: specific controls, monitoring requirements, re-review date
- HoD approves with digital sign-off — full audit trail
- Accepted risks tagged — auto-excluded from all dashboards and board reports
- Re-review reminder at 90 days — HoD must re-approve or remediate

5.4 VAPT Vendor Portal

Vendor Login	Guest/Vendor role assigned by Royal Enfield. Scoped — vendor sees only their own submissions
Structured Entry	Form: Vulnerability name, CVE ID, CVSS, Affected Asset, Exploit Maturity, PoC evidence upload. Real-time validation.
File Upload	PDF/Excel parser for legacy reports. Normalizes to unified schema automatically.
Auto-Processing	On submission: EPSS + KEV enrichment, auto-assigned to owner, SLA timer starts. Zero manual work.
Re-test Flow	IT fixes vulnerability → 'Request Re-test' → Vendor notified → Pass/Fail logged with evidence → Auto-close on Pass

6. Demo — Sample Risk Register

Representative sample of how the unified risk register will appear in the portal. All data is illustrative for demonstration purposes.

ID	Finding	Source	CVSS	Severity	Owner	Status
RE-001	Unpatched RCE — Public Web App	VAPT	9.8	**Critical**	App Team	Open
RE-002	Log4j on Production Server	Spotlight	9.0	**Critical**	Infra Team	In Progress
RE-003	Unencrypted OT Protocol	OT (Armis)	8.5	**High**	OT Team	Open
RE-004	Shadow IT App Detected	CNAPP	7.2	**High**	Cloud Team	Assigned
RE-005	CERT-In Advisory CVE-2026-1234	CERT-In	7.0	**High**	Infra Team	Open
RE-006	Rogue Device on LAN	SoC Alert	6.5	**Medium**	Network Team	Resolved
RE-007	Shared Admin Password	Spotlight	6.1	**Medium**	IAM Team	Accepted
RE-008	IDOR in HR Portal	Bug Bounty	5.4	**Medium**	App Team	In Progress
RE-009	Open S3 Bucket	EASM	4.8	**Medium**	Cloud Team	Open
RE-010	Expired SSL — Internal Portal	EASM	2.5	**Low**	App Team	Backlog

Note: RE-007 (Accepted) auto-excluded from executive and board reports. Compensating control applied: CyberArk session isolation enabled, quarterly password rotation enforced, re-review in 90 days.

7. Implementation Plan

Enterprise API integrations, custom parsers, and UAT in a 7,000-endpoint environment require realistic timelines. The plan below reflects an honest 6-month delivery schedule.

Phase	Timeline	Deliverable	Milestone
Phase 1	Month 1	CrowdStrike + Armis API connectors. OT network access architecture (On-Prem Collector or Proxy). Unified schema design.	Core data flowing
Phase 2	Month 2	Risk register portal. Composite scoring engine. VAPT portal + file parser. Owner assignment + SLA engine.	Register live
Phase 3	Month 3	Risk acceptance workflow. HoD approval flow. Compensating controls recommendation engine. Jira/ServiceNow integration.	Workflow live
Phase 4	Month 4	Executive dashboard. CISO + Board + CERT-In reports. Role-based access. APT tagging + IOC matching wire-in.	Demo ready
Phase 5	Month 5	Remaining connectors (CERT-In, Bug Bounty, SoC, Forescout, Zscaler, CyberArk, Fortiguard, Google). UAT with RE IT team.	Full system live
Phase 6	Month 6	Go-live. Performance testing at 7,000 endpoints. Ops team training. Handover. Infra support begins.	Production

8. Commercial Model

Model	1-time platform delivery + subscription support
Endpoint Tier	Priced per endpoint tier — covers Royal Enfield's current environment with headroom for growth
Subscription	2-year initial term, renewable annually
Includes	All 14 source connectors, portal, dashboards, reports, OTX + MITRE integrations, infra support
Ops Handover	Portal operations handed to Royal Enfield IT team post Phase 6
Support Model	Semantic Gravity: Infra-level support + connector maintenance. Royal Enfield: Day-to-day ops
Zero Extra Cost	OTX (free), MITRE ATT&CK (free), CISA KEV (free), EPSS (free) — no additional licensing
Paid Exception	Dark web monitoring (SpyCloud/Recorded Future) — optional add-on if client requires real monitoring

9. What We Need From Royal Enfield

01 — Tool APIs	CrowdStrike read-only API key. Armis API credentials. Zscaler CASB API token. SoC SIEM webhook or API.
02 — OT Network Access	Network topology of Armis segment. Decision: On-Premise Collector or Secure API Gateway approach.
03 — CMDB / Tags	CrowdStrike asset criticality tags export or ServiceNow CMDB Business Criticality field access — for asset tiering.
04 — VAPT Sample	One sample VAPT report (PDF or Excel) — to finalize import parser and normalization mapping.
05 — Risk Scoring Logic	How do you currently rate/categorize Bug Bounty (P1/P2?) and SoC alerts? CERT-In response process?
06 — Ticketing Tool	Jira or ServiceNow? Project/board structure for vulnerability tickets.
07 — Competitor Quotes	Quotes from other vendors evaluated — for commercial benchmarking.

10. FAQ — Anticipated Questions & Answers

Q: We already use CrowdStrike which does composite scoring. Why do we need URIP?

CrowdStrike's ExPRT scoring is excellent — for CrowdStrike findings only. Your VAPT reports, CERT-In advisories, Bug Bounty findings, and SoC alerts are not scored by CrowdStrike. URIP takes CrowdStrike's already-computed score, normalizes it to the same scale as all other sources, and gives you one unified register across all 14 inputs.

Q: What if CrowdStrike and Armis report the same vulnerability on the same machine?

URIP de-duplicates using Asset Fingerprinting — MAC Address + Hostname + IP. If two sources report the same CVE on the same asset, they are merged into one finding. The highest enriched composite score is retained. Source attribution is preserved so you know both tools flagged it.

Q: How are you reaching Armis data if OT is in a separate network segment?

URIP supports two approaches: (A) On-Premise Collector — a lightweight agent deployed inside the OT segment that pulls Armis API locally and sends encrypted data to URIP. (B) Secure API Gateway — a proxy in the DMZ between the OT segment and URIP. Neither option exposes the OT network directly to the internet.

Q: How do you handle API rate limits — especially Zscaler?

Each connector implements batched polling, token refresh, and exponential backoff on rate-limit responses. EPSS is cached for 24 hours (reducing calls by ~95%). CISA KEV is downloaded once daily as a full JSON file. Zscaler is polled on 15-minute intervals within their rate guidance.

Q: The 6-month timeline — can it really be done?

Yes — with client cooperation on API access and UAT. The core portal and scoring engine are already built. Months 1-3 are about connecting your specific tool stack and validating data quality. Months 4-6 are integration hardening, UAT, and go-live. The timeline is realistic for a 7,000-endpoint environment with 14 sources.

Q: What if our asset names don't follow naming conventions?

Keyword matching is only a failsafe. The primary method is CrowdStrike's asset_criticality tag and ServiceNow CMDB Business Criticality field — both of which are already maintained by your IT team.

Assets that are already tagged in CrowdStrike are automatically classified correctly, regardless of naming convention.

Q: What is the platform's scalability beyond current endpoint count?

The platform is built to scale. Endpoint-tier licensing means growth beyond current numbers triggers a simple subscription upgrade at renewal — no architectural changes. The scoring and deduplication engine is stateless and horizontally scalable.

11. Recommended Enhancements

The following features are not yet implemented but are recommended for inclusion in a future sprint based on demo feedback and client requirements.

11.1 Threat Map — Word Cloud Visualization

Currently the Threat Map displays a geographic visualization of attack origins, sector heatmaps, and India-specific threat clusters. A recommended enhancement is the addition of contextual Word Clouds alongside the map.

RECOMMENDATION — Three Contextual Word Clouds on Threat Map

Word Cloud 1 — Threat Actors	Most active APT groups targeting the client's sector. Size of word = frequency of activity. Example: APT28, APT41, Lazarus, Sandworm, LockBit.
Word Cloud 2 — Attack Techniques	Most common TTPs observed in current threat pulses. Example: Phishing, RCE, Credential Theft, Supply Chain, Ransomware, SQLi.
Word Cloud 3 — Targeted Sectors	Industries most frequently targeted in active campaigns. Example: Manufacturing, Defense, Energy, Automotive, Government.

Why Three, Not One	A single generic word cloud loses context. Three labeled clouds give the CISO an instant answer: WHO is attacking, HOW they attack, and WHO ELSE they target — without reading a table.
Industry Precedent	Word clouds are used in Splunk dashboards, Recorded Future, and ThreatConnect threat intelligence portals. Well-established pattern in security operations.
Demo Impact	High — board-level visual. One glance shows Indian manufacturing is under active threat from named APT groups using known techniques. No table reading required.
Implementation	Data already available from MITRE ATT&CK + OTX pulse feeds. Frontend: D3.js or Chart.js word cloud plugin. Estimated effort: 1-2 days.

Status	Recommended — not yet implemented. Proposed for next sprint post demo feedback.

Semantic Gravity · contact@semanticgravity.in · Demo: May 2026

Appendix — Glossary of Key Terms

Quick reference for all abbreviations and terms used in this document and the Gurgaon demo.

GROUP 1 — SCORING (How We Measure the Problem)

Term	Full Name	Managed By	Simple Function
CVE	Common Vulnerabilities & Exposures	MITRE	The ID Number for a bug. Every vulnerability has a unique name (e.g., CVE-2024-123).
CVSS	Common Vulnerability Scoring System	FIRST.org	The Size of the hole. Score 0-10. 10 = giant hole, 1 = tiny crack.
EPSS	Exploit Prediction Scoring System	FIRST.org	The Probability. % chance a bad actor will actually exploit that hole in the next 30 days.
KEV	Known Exploited Vulnerabilities	CISA	The Weapon List. Official government list of CVEs confirmed in active use by attackers right now.
SSVC	Stakeholder-Specific Vulnerability Categorization	CISA / SEI	The Decision. A label — ACT NOW / ACT / ATTEND / TRACK — telling the team what to do next.
SLA	Service Level Agreement	Internal	The Timer. Rule that says 'You have 72 hours to fix a Critical bug.' Tracked on the URIP dashboard.

GROUP 2 — THREATS (The Bad Guys)

Term	Full Name	Managed By	Simple Function
APT	Advanced Persistent Threat	CrowdStrike / MITRE	The Gangs. Professional hacker armies (like 'APT28') often funded by nation-states.
IOC	Indicator of Compromise	Logs / SIEM	The Fingerprint. Evidence (like a malicious IP address) that a bad actor was inside your network.
TTP	Tactics, Techniques & Procedures	MITRE ATT&CK	The Method. How attackers operate — e.g., do they exploit a web app or steal credentials?
TLP	Traffic Light Protocol	Industry Standard	The Secrecy Color. Red = Top Secret, Amber = Limited Sharing, Green = General info.

GROUP 3 — ORGANIZATIONS (Sources of Truth)

Term	Full Name	Type	Simple Function
CISA	Cybersecurity & Infrastructure	US Gov Agency	The Police Chief. Issues official orders

	Security Agency		and manages the KEV list.
MITRE	MITRE (proper name, not abbreviation)	Research Org	The Librarian. Creates CVE names and maintains the ATT&CK framework of APT tactics.
CERT-In	Indian Computer Emergency Response Team	Indian Gov Agency	The Indian Authority. Issues advisories and responds to cyber incidents in India.
NIST	National Institute of Standards & Technology	US Gov Agency	The Standard Setter. Defines what a good security program looks like (NIST CSF).
FIRST	Forum of Incident Response & Security Teams	Global Org	The Score Keeper. Manages CVSS and EPSS scoring standards.

GROUP 4 — THE CORE 9 RISK SOURCES

Term	Full Name / Tool	RE Tool	Simple Function
VM / Spotlight	Vulnerability Management	CrowdStrike Falcon	Looks inside computers to find old, weak software with known bugs.
EASM	External Attack Surface Management	CrowdStrike / External	Looks at the company from the outside (internet) to find open doors.
CNAPP	Cloud Native Application Protection Platform	CrowdStrike Cloud	Protects cloud servers (AWS/Azure) from misconfigurations and threats.
OT	Operational Technology	Armis	Protects factory machines and industrial equipment (the robots building the bikes).
VAPT	Vulnerability Assessment & Penetration Testing	External Vendor	Ethical hackers you pay to try and break in — they find holes and report them.
Threat Intel	Threat Intelligence	External Feed	A live news feed about what bad actors are doing globally, right now.
CERT-In	Indian Computer Emergency Response Team	Indian Gov Agency	The Indian Authority. Issues official advisories when new critical vulnerabilities are discovered. Compliance mandatory for Indian enterprises.
Bug Bounty	Bug Bounty Program	Internal/External	Paying independent researchers a reward to responsibly report bugs they find.
SoC	Security Operations Center	SIEM / SoC Team	The 24/7 watch center — people monitoring screens for live attacks and alerts.

GROUP 5 — THE EXTENDED 5 SECURITY TOOLS

Term	Full Name	RE Tool	Simple Function
NAC	Network Access Control	Forescout / Cisco ISE	The Bouncer. Checks if a device is authorized to be on the company network.
PAM	Privileged Access Management	CyberArk	The Safe. Holds and controls the super-powerful admin passwords.
CASB	Cloud Access Security Broker	Zscaler ZTA / ZIA	The Internet Filter. Stops users from accessing unauthorized or malicious cloud apps.

Firewall	Next-Gen Firewall	Fortiguard	The Castle Wall. Blocks malicious traffic from entering or leaving the network.
Email Sec	Email Security	Google Workspace	The Mail Room Inspector. Stops phishing and malicious emails before they reach users.

Semantic Gravity · contact@semanticgravity.in · Demo: May 2026